Lab nmap — Reconnaissance de Metasploitable3

Oct 20, 2026 · François Paquin, CISSP

Présentation du lab

À la fin de ce lab, vous serez capable de cartographier les services d'une machine cible avec nmap, d'identifier leurs versions et de repérer ceux qui méritent une analyse plus poussée.

Objectifs d'apprentissage

1. Découvrir les hôtes actifs d'un réseau.
2. Distinguer les principaux types de scans et les états de ports.
3. Identifier les services, leurs versions et le système d'exploitation d'une cible.
4. Utiliser quelques scripts NSE pour enrichir la reconnaissance.
5. Produire un inventaire des services exposés et justifier des priorités d'analyse.

Environnement : une VM Kali (attaquant) et une VM Metasploitable3 (cible volontairement vulnérable), sur un réseau isolé du cyber range.

Livrable : un court rapport répondant aux questions de l'exercice, accompagné des fichiers de sortie nmap.

> ***Mise en garde éthique et légale*** *— Scanner un système sans autorisation peut constituer une infraction au Code criminel (art. 342.1, utilisation non autorisée d'ordinateur). Dans ce lab, vous scannez* ***uniquement*** *la VM Metasploitable3 qui vous est assignée. Aucun scan vers Internet, vers les VM de vos collègues ou vers le réseau du Cégep.*

Introduction à nmap

nmap (*Network Mapper*) répond à trois questions : quels hôtes sont actifs, quels ports sont ouverts, et quels services (et versions) écoutent derrière. C'est l'outil de base de la phase de **reconnaissance** d'un test d'intrusion, mais aussi un outil de défense : un administrateur l'utilise pour vérifier que seuls les services prévus sont exposés.

Ports, protocoles et services

Un port est un numéro (0 à 65 535) qui permet à un hôte de distinguer plusieurs services sur une même adresse IP. Les ports 0 à 1023 sont les ports « bien connus », réservés aux services standards (22 pour SSH, 80 pour HTTP). Un service peut toutefois écouter sur n'importe quel port : un numéro de port est un **indice**, jamais une preuve.

- **TCP** est orienté connexion : poignée de main SYN → SYN/ACK → ACK avant tout échange.
- **UDP** n'a pas de connexion : on envoie et on espère une réponse. Les scans UDP sont donc lents et moins fiables.

Les états de ports selon nmap

État	Signification
open	Un service accepte les connexions sur ce port.
closed	L'hôte répond, mais aucun service n'écoute (réponse RST).
filtered	Aucune réponse ou réponse ICMP d'erreur : un pare-feu filtre probablement.
unfiltered	Le port est accessible, mais nmap ne peut dire s'il est ouvert ou fermé (scan ACK).
open|filtered	nmap ne peut trancher entre ouvert et filtré (fréquent en UDP).

Les grandes familles de scans

1. **Découverte d'hôtes** (`-sn`) : qui est en ligne ? Aucun port n'est scanné.
2. **Scan SYN** (`-sS`, défaut en root) : envoie un SYN, lit la réponse, puis abandonne la connexion. Rapide et « semi-ouvert ».
3. **Scan Connect** (`-sT`, défaut sans privilèges) : complète la poignée de main. Plus bruyant, mais ne requiert pas root.
4. **Scan UDP** (`-sU`) : sonde les services UDP (DNS, SNMP, NTP). À limiter aux ports principaux.
5. **Détection de versions** (`-sV`) : interroge chaque port ouvert pour identifier le logiciel et sa version.
6. **Détection d'OS** (`-O`) : déduit le système d'exploitation à partir des particularités de la pile TCP/IP.
7. **Scripts NSE** (`-sC`, `--script`) : le *Nmap Scripting Engine* ajoute des centaines de scripts d'énumération et de détection de vulnérabilités.

Choisir les ports

Par défaut, nmap scanne les **1 000 ports TCP les plus courants**, pas les 65 535. Un service sur un port inhabituel peut donc passer inaperçu. `-p-` scanne tous les ports ; `--top-ports 100` limite aux 100 plus fréquents.

Vitesse et discrétion

Les gabarits de timing vont de `-T0` (paranoïaque, très lent) à `-T5` (insensé). `-T4` convient bien à un lab. Sur un vrai réseau, un scan rapide déclenche les alertes d'un IDS : la vitesse est un compromis entre efficacité et discrétion.

Sauvegarder les résultats

Toujours conserver ses résultats : `-oN` (texte lisible), `-oX` (XML, pour d'autres outils), `-oG` (« grepable ») ou `-oA` (les trois d'un coup). Un pentest se documente au fur et à mesure.

Mise en place

Avant de scanner, confirmez votre propre adresse et le réseau dans lequel vous vous trouvez.

1. Dans un terminal Kali, affichez votre configuration réseau : `ip a`
2. Notez votre adresse IP et le masque (ex. `192.168.56.10/24`). Le réseau à analyser est celui de cette interface.
3. Créez un dossier de travail pour vos résultats : `mkdir -p ~/lab-nmap && cd ~/lab-nmap`
4. Vérifiez que nmap est installé : `nmap --version`
5. Certains scans (`-sS`, `-sU`, `-O`) exigent les privilèges root : préfixez-les de `sudo`.

> *Ne cherchez pas encore l'adresse de Metasploitable3 : la trouver est la première étape de l'exercice.*

Exercice : la mission de reconnaissance

Mise en situation — Une PME vous mandate pour un test d'intrusion. Votre lettre d'autorisation couvre un seul serveur sur le réseau du lab. Vous ne connaissez ni son adresse, ni son système, ni ses services. Votre mission : en dresser l'inventaire complet et indiquer au client par où un attaquant commencerait.

Remplacez `<RÉSEAU>` par votre réseau (ex. `192.168.56.0/24`) et `<CIBLE>` par l'adresse trouvée à l'étape 1.

Étape 1 — Trouver la cible

```
sudo nmap -sn <RÉSEAU> -oN 01-decouverte.txt
```

- **Q1.** Combien d'hôtes sont actifs ? Lesquels pouvez-vous éliminer (votre Kali, la passerelle) ?
- **Q2.** Quelle est l'adresse de la cible ? Quel indice (adresse MAC, fabricant de la carte réseau) vous aide à l'identifier ?

Étape 2 — Premier coup d'œil

```
sudo nmap <CIBLE> -oN 02-defaut.txt
```

- **Q3.** Combien de ports ouverts nmap rapporte-t-il ? Combien de ports a-t-il réellement testés ?
- **Q4.** Pour chaque port ouvert, notez le service que nmap *suppose*. Sur quoi se base-t-il à cette étape ?
- **Q5.** Comparez avec l'aide-mémoire des ports : y a-t-il des ports que vous ne reconnaissez pas ?

Étape 3 — SYN ou Connect ?

Lancez les deux scans suivants dans deux terminaux, avec Wireshark ouvert sur votre interface (filtre : `ip.addr == <CIBLE> && tcp.port == 22`).

```
sudo nmap -sS -p 22 <CIBLE>
nmap -sT -p 22 <CIBLE>
```

- **Q6.** Décrivez la séquence de paquets observée pour chaque scan. Lequel complète la poignée de main ?
- **Q7.** Lequel de ces scans risque davantage d'être journalisé par le service lui-même ? Pourquoi ?

Étape 4 — Ne rien manquer

```
sudo nmap -p- -T4 <CIBLE> -oN 04-tous-ports.txt
```

- **Q8.** Quels ports ouverts apparaissent ici, mais pas à l'étape 2 ? Pourquoi le scan par défaut les a-t-il manqués ?
- **Q9.** Combien de temps a pris ce scan comparé à celui de l'étape 2 ? Quel compromis cela illustre-t-il ?

Étape 5 — Identifier les versions et l'OS

Réutilisez la liste des ports trouvés à l'étape 4 (ex. `-p 21,22,80,...`) pour gagner du temps.

```
sudo nmap -sV -O -p <PORTS> <CIBLE> -oA 05-versions
```

- **Q10.** Quel système d'exploitation nmap détecte-t-il ? Avec quel degré de confiance ?
- **Q11.** Complétez le tableau d'inventaire ci-dessous pour **tous** les ports ouverts.
- **Q12.** Trouvez au moins un service qui écoute sur un port *non standard*. Comment `-sV` l'a-t-il identifié malgré tout ?

Port/protocole	Service supposé (étape 2)	Produit et version (-sV)	Rôle probable du service

Étape 6 — Les services UDP

```
sudo nmap -sU --top-ports 20 <CIBLE> -oN 06-udp.txt
```

- **Q13.** Quels ports UDP sont `open` ? Lesquels sont `open|filtered`, et pourquoi nmap ne peut-il pas trancher ?

Étape 7 — Aller plus loin avec NSE

Lancez les scripts par défaut, puis quelques scripts ciblés selon les services que vous avez trouvés.

```
sudo nmap -sC -sV -p <PORTS> <CIBLE> -oN 07-scripts.txt
nmap --script ftp-anon -p 21 <CIBLE>
nmap --script http-title,http-headers,http-enum -p <PORTS_WEB> <CIBLE>
nmap --script smb-os-discovery,smb-enum-shares -p 445 <CIBLE>
```

- **Q14.** Le FTP permet-il la connexion anonyme ? Quelle serait la conséquence pour l'entreprise ?
- **Q15.** Pour chaque service web, notez le titre de la page. Quelles applications sont hébergées ?
- **Q16.** Quelle information `smb-os-discovery` révèle-t-il (nom de l'hôte, domaine, OS) ?

Étape 8 — Analyse et recommandations

Aucune commande ici : c'est le travail d'analyste.

- **Q17.** Classez les **trois** services qui vous semblent les plus prioritaires à analyser. Justifiez chaque choix (version ancienne, accès anonyme, interface d'administration exposée, service inutile, etc.).

- **Q18.** Pour un des services trouvés, cherchez sa version sur la base CVE ou avec `searchsploit <produit> <version>`. Qu'en concluez-vous ?
- **Q19.** Rédigez deux recommandations concrètes au client pour réduire sa surface d'attaque.

Défis bonus et réflexion

Défis

- **B1. Le scanner furtif** — Refaites le scan de l'étape 2 avec `-T1`, puis avec `-T5`. Comparez la durée et le nombre de ports trouvés. Un des deux a-t-il manqué des ports ?
- **B2. Le chasseur de vulnérabilités** — Lancez `nmap --script vuln -p <PORTS> <CIBLE>`. Quelles vulnérabilités sont signalées ? Lesquelles vous semblent être de faux positifs ?
- **B3. Le parseur** — À partir du fichier `05-versions.gnmap`, écrivez une ligne de commande (`grep`, `cut`, `awk`) qui affiche seulement les ports ouverts et leur service.
- **B4. Le rapport** — Convertissez `05-versions.xml` en page web : `xsltproc 05-versions.xml -o rapport.html`. Ouvrez-la dans Firefox.
- **B5. La bannière à la main** — Connectez-vous à un service avec `nc <CIBLE> <PORT>` (ex. FTP ou SSH). Que vous dit la bannière ? Comparez avec le résultat de `-sV`.

Questions de réflexion

1. Vous êtes maintenant l'administrateur de ce serveur. Quels indices, dans vos journaux ou dans un IDS, trahiraient le scan que vous venez de faire ?
2. Pourquoi un pentesteur ne se contente-t-il jamais du scan par défaut de 1 000 ports ?
3. Un port affiché `filtered` est-il une bonne ou une mauvaise nouvelle pour le défenseur ? Pour l'attaquant ?
4. Le serveur que vous avez scanné est volontairement vulnérable. Quels de ses services n'auraient jamais dû être exposés en production ?

Volet bonus : reconnaissance IoT

En entreprise, une bonne partie des appareils du réseau ne sont pas des ordinateurs : caméras, imprimantes, thermostats, capteurs, automates de production. Dans le secteur privé, ils sont souvent installés par des fournisseurs, rarement inventoriés et presque jamais mis à jour. Les reconnaître fait partie du travail de tout analyste.

Mise en situation — Le même client vous demande d'étendre le mandat à son réseau d'usine. Le responsable des opérations s'inquiète : « Surtout, ne faites pas planter la ligne de production. » Votre lettre d'autorisation couvre une seule adresse, celle de la passerelle IoT du lab (`<IOT>`).

> ***Règle d'or en OT/IoT*** *— Ces appareils sont fragiles : un scan agressif peut les redémarrer ou les figer. Ici, on travaille en `-T2`, on cible les ports et on n'utilise ni `-A`, ni `-p-` en vitesse élevée, ni scripts de force brute.*

Repérer un appareil IoT

Trois indices se combinent :

1. **Le fabricant de la carte réseau** (OUI de l'adresse MAC), affiché par nmap sur le réseau local : Hikvision, Espressif, Tuya, Siemens, etc.
2. **Le type d'appareil** rapporté par `-O` (`webcam`, `printer`, `specialized`, `embedded`) et les bannières lues par `-sV` (BusyBox, lighttpd, GoAhead, Dropbear).
3. **Les ports caractéristiques**, résumés ci-dessous.

Port	Service	Appareils typiques
23, 2323	Telnet	Caméras, routeurs bas de gamme (cible du botnet Mirai)
102	Siemens S7	Automates industriels Siemens
161/UDP	SNMP	Imprimantes, équipements réseau, onduleurs
502	Modbus	Automates, compteurs, systèmes de bâtiment
554	RTSP	Caméras IP, enregistreurs vidéo (NVR)
1883, 8883	MQTT, MQTTS	Capteurs, domotique, passerelles IoT
1900/UDP	UPnP / SSDP	Téléviseurs, routeurs, caméras
5353/UDP	mDNS	Chromecast, imprimantes, appareils HomeKit
5683/UDP	CoAP	Capteurs à faible consommation
7547	TR-069	Modems de fournisseurs d'accès
8000, 37777	Hikvision, Dahua	Caméras et NVR
9100	JetDirect	Imprimantes réseau
44818	EtherNet/IP	Automates Rockwell / Allen-Bradley
47808/UDP	BACnet	Gestion de bâtiment (CVC, éclairage)

Étape I1 — Inventaire prudent

```
sudo nmap -sS -sU -T2 -p
T:23,80,102,502,554,1883,8000,9100,44818,U:161,1900,5683,47808 <IOT> -oN i1-iot.txt
```

- **QI1.** Quels ports sont ouverts ? D'après le tableau, quel type d'appareil suspectez-vous ?
- **QI2.** Pourquoi avoir choisi `-T2` et une liste de ports plutôt que `-p- -T4` ?

Étape I2 — Inventaire plus aggressif pas mal!

```
nmap -sS -sU -sV -p T:23,80,102,502,554,1883,8000,9100,44818,U:161,1900,5683,47808 -O
--script snmp-sysdescr,upnp-info,coap-resources,bacnet-info,modbus-discover,s7-
info,enip-info 10.0.0.0/24
```

Étape I3 — Faire parler l'automate

```
nmap -T2 -p 502 --script modbus-discover <IOT>
nmap -T2 -p 102 --script s7-info <IOT>
sudo nmap -T2 -sU -p 161 --script snmp-sysdescr <IOT>
sudo nmap -T2 -sU -p 47808 --script bacnet-info <IOT>
```

- **QI3.** Quels sont le fabricant, le modèle et la version de firmware rapportés ?
- **QI4.** Aucun de ces protocoles n'a demandé d'authentification. Quelle conséquence cela a-t-il pour un attaquant déjà présent sur le réseau ?

Étape I4 — Écouter les capteurs

```
nmap -T2 -p 1883 --script mqtt-subscribe <IOT>
```

Puis abonnez-vous vous-même à tous les sujets (installer le client au besoin : `sudo apt install mosquitto-clients`) :

```
mosquitto_sub -h <IOT> -t '#' -v
```

- **QI5.** Quels sujets (*topics*) et quelles valeurs voyez-vous passer ?
- **QI6.** Le broker a accepté une connexion anonyme. Un attaquant pourrait-il aussi *publier* de fausses valeurs ? Quel impact sur une usine ?

Étape I5 — Découvrir sans cibler

Ces scripts n'ont pas besoin d'adresse : ils écoutent les annonces diffusées sur le réseau local.

```
sudo nmap --script broadcast-upnp-info,broadcast-dns-service-discovery
```

- **QI7.** Quels appareils se sont annoncés d'eux-mêmes ? Pourquoi cette technique est-elle à la fois discrète et efficace ?

Réflexion

1. Proposez trois mesures pour protéger ce réseau d'usine (segmentation, inventaire, authentification, mises à jour).
2. Dans le secteur public, l'ajout d'un appareil connecté passe généralement par une évaluation de sécurité et une autorisation formelle. En entreprise privée, ce n'est souvent pas le cas. Quels risques ce manque d'encadrement crée-t-il, et comment un analyste peut-il le compenser ?

Aide-mémoire nmap

Les options les plus utiles, regroupées par usage. Elles se combinent librement : `sudo nmap -sS -sV -O -p- -T4 -oA scan <CIBLE>`.

Catégorie	Option	Effet
Cible	`192.168.56.101`	Un seul hôte
Cible	`192.168.56.0/24`	Tout un sous-réseau (notation CIDR)
Cible	`192.168.56.100-150`	Une plage d'adresses
Cible	`-iL cibles.txt`	Lire les cibles dans un fichier
Découverte	`-sn`	Découverte d'hôtes seulement, sans scan de ports
Découverte	`-Pn`	Sauter la découverte, considérer l'hôte actif (utile si le ping est bloqué)
Découverte	`-n`	Pas de résolution DNS (plus rapide)
Type de scan	`-sS`	Scan SYN, semi-ouvert (root)
Type de scan	`-sT`	Scan Connect, poignée de main complète
Type de scan	`-sU`	Scan UDP
Type de scan	`-sA`	Scan ACK, pour cartographier les règles de pare-feu
Ports	`-p 22` / `-p 21-25` / `-p 22,80,443`	Port précis, plage ou liste
Ports	`-p-`	Les 65 535 ports
Ports	`-F`	Mode rapide : les 100 ports les plus courants
Ports	`--top-ports 20`	Les N ports les plus courants
Ports	`-p U:161,T:22`	Mélanger UDP et TCP
Identification	`-sV`	Détection des services et de leurs versions
Identification	`-O`	Détection du système d'exploitation (root)
Identification	`-A`	Agressif : `-sV -O -sC --traceroute`
Scripts NSE	`-sC`	Scripts par défaut (catégorie *default*)
Scripts NSE	`--script <nom>`	Un script ou une catégorie (`vuln`, `auth`, `discovery`, `safe`)
Scripts NSE	`--script-help <nom>`	Afficher l'aide d'un script

Catégorie	Option	Effet
Timing	`-T0` à `-T5`	De très lent et discret à très rapide et bruyant (`-T3` par défaut)
Sortie	`-oN fichier.txt`	Sortie normale (texte)
Sortie	`-oX fichier.xml`	Sortie XML
Sortie	`-oG fichier.gnmap`	Sortie « grepable »
Sortie	`-oA nom`	Les trois formats d'un coup
Affichage	`-v` / `-vv`	Plus de détails en temps réel
Affichage	`--open`	N'afficher que les ports ouverts
Affichage	`--reason`	Expliquer pourquoi un port est dans tel état

Astuce : pendant un long scan, appuyez sur la barre d'espace pour voir la progression. Les scripts NSE sont dans `/usr/share/nmap/scripts/` ; `ls /usr/share/nmap/scripts/ | grep smb` liste ceux pour SMB.

Aide-mémoire des ports et services

Les ports par défaut des services les plus courants, triés par numéro. Rappel : un service peut écouter sur n'importe quel port, seul `-sV` le confirme. La liste complète de nmap est dans `/usr/share/nmap/nmap-services`.

Ports bien connus (0 à 1023)

Port	Protocole	Service	Description	À surveiller
20, 21	TCP	FTP	Transfert de fichiers (21 : contrôle, 20 : données)	Identifiants en clair, accès anonyme
22	TCP	SSH	Administration à distance chiffrée, SFTP, SCP	Force brute, versions anciennes
23	TCP	Telnet	Administration à distance non chiffrée	Tout passe en clair : à proscrire
25	TCP	SMTP	Envoi et relais de courriel	Relais ouvert, énumération d'usagers (VRFY)
53	TCP/UDP	DNS	Résolution de noms	Transfert de zone (AXFR), amplification
67, 68	UDP	DHCP	Attribution automatique d'adresses IP	Serveur DHCP pirate

Port	Protocole	Service	Description	À surveiller
69	UDP	TFTP	Transfert de fichiers simplifié, sans authentification	Lecture de fichiers de configuration
80	TCP	HTTP	Web non chiffré	Applications web vulnérables
88	TCP/UDP	Kerberos	Authentification Active Directory	Indique un contrôleur de domaine
110	TCP	POP3	Récupération de courriel	Identifiants en clair
111	TCP/UDP	RPCbind	Annuaire des services RPC (Unix)	Énumération des services NFS
123	UDP	NTP	Synchronisation de l'heure	Amplification DDoS
135	TCP	MSRPC	Appels de procédure à distance Microsoft	Énumération Windows
137-139	TCP/UDP	NetBIOS	Noms et sessions de partage Windows (ancien)	Fuite du nom d'hôte et du domaine
143	TCP	IMAP	Accès au courriel sur le serveur	Identifiants en clair
161, 162	UDP	SNMP	Supervision d'équipements réseau	Communauté « public » par défaut
389	TCP/UDP	LDAP	Annuaire (Active Directory)	Requêtes anonymes
443	TCP	HTTPS	Web chiffré (TLS)	Certificats, versions TLS obsolètes
445	TCP	SMB	Partage de fichiers Windows, Samba	EternalBlue (MS17-010), partages ouverts
465, 587	TCP	SMTPS / Submission	Envoi de courriel authentifié et chiffré	Force brute
514	UDP	Syslog	Journalisation centralisée	Messages en clair, injection
631	TCP	IPP / CUPS	Impression	Interface d'administration exposée
636	TCP	LDAPS	LDAP chiffré	Certificats
993	TCP	IMAPS	IMAP chiffré	Force brute

Port	Protocole	Service	Description	À surveiller
995	TCP	POP3S	POP3 chiffré	Force brute

Ports enregistrés et applicatifs (1024 et plus)

Port	Protocole	Service	Description	À surveiller
1099	TCP	Java RMI	Appels d'objets Java à distance	Désérialisation, exécution de code
1433	TCP	MS SQL Server	Base de données Microsoft	Compte « sa » faible
1521	TCP	Oracle	Base de données Oracle	Identifiants par défaut
2049	TCP/UDP	NFS	Partage de fichiers Unix	Exports montables par tous
3306	TCP	MySQL / MariaDB	Base de données	Compte root sans mot de passe
3389	TCP	RDP	Bureau à distance Windows	Force brute, BlueKeep
5432	TCP	PostgreSQL	Base de données	Identifiants par défaut
5900	TCP	VNC	Bureau à distance multiplateforme	Mot de passe faible ou absent
5985, 5986	TCP	WinRM	Gestion à distance Windows / PowerShell (HTTP, HTTPS)	Exécution de commandes à distance
6379	TCP	Redis	Base clé-valeur en mémoire	Aucune authentification par défaut
6667, 6697	TCP	IRC	Messagerie instantanée (6697 : TLS)	Versions piégées (UnrealIRCd)
8080	TCP	HTTP alternatif	Serveurs d'applications, proxys (Tomcat, Jenkins)	Consoles d'administration
8443	TCP	HTTPS alternatif	Interfaces web d'administration	Identifiants par défaut
9200	TCP	Elasticsearch	Moteur de recherche et d'indexation	API ouverte, fuite de données

Port	Protocole	Service	Description	À surveiller
27017	TCP	MongoDB	Base de données NoSQL	Aucune authentification par défaut
49152-65535	TCP/UDP	Ports dynamiques	Ports éphémères, RPC dynamique Windows	Normaux côté client

Truc mnémotechnique : le courriel *envoie* sur 25, *reçoit* sur 110 (POP) et 143 (IMAP) ; la version chiffrée d'un service se trouve souvent « plus haut » (80 → 443, 143 → 993, 110 → 995, 389 → 636).